



DEPARTMENT CIRCULAR NO. **HRA-002**

JAN 14 2026

Series of 2026

SUBJECT : PRESCRIBING THE REVISED AND CONSOLIDATED GUIDELINES, RULES, AND REGULATIONS GOVERNING THE VULNERABILITY DISCLOSURE INITIATIVE, SAFE HARBOR POLICY, AND BUG BOUNTY PROGRAM

WHEREAS, Sec. 2, par (m) of the Republic Act No. 10844, otherwise known as the “Department of Information and Communications Technology (DICT) Act of 2015,” mandates the Department to ensure the security of critical ICT infrastructures including information assets of the government, individuals and businesses;

WHEREAS, the Cybercrime Prevention Act of 2012 (Republic Act No. 10175) and the Data Privacy Act of 2012 (Republic Act No. 10173) emphasize the protection of information and the accountability of those accessing or handling it;

WHEREAS, Executive Order No. 58, s. 2024 adopted the National Cybersecurity Plan (NCSP) 2023-2028 as the whole-of-nation roadmap for the integrated development and strategic direction of the country’s cybersecurity;

WHEREAS, Strategy 3.7.2 of the NCSP 2023-2028 is to strengthen the cybersecurity policy framework by creating a safe environment for security researchers to responsibly disclose cybersecurity vulnerabilities and incidents;

WHEREAS, DICT Department Circular No. 006, s. 2024 prescribes guidelines for the vulnerability disclosure initiative and recognizes that ethical cybersecurity research and responsible vulnerability disclosure are essential to improving the cybersecurity posture of a country, including the Philippines;

WHEREAS, to effectively operationalize DC No. 006, s. 2024, there is a need to further clarify the roles and responsibilities of participating entities and researchers, establish a safe harbor for ethical cybersecurity research, and institute a structured incentive mechanism;

WHEREAS, the State recognizes the contributions of the cybersecurity community and seeks to establish a Safe Harbor Policy to protect good-faith researchers, and a Bug Bounty Program to incentivize responsible reporting of security vulnerabilities across both public and private sectors;

WHEREAS, the DICT, through its Cybersecurity Bureau, is mandated to lead the development of national cybersecurity policies and to promote collaboration between the public and private sectors;

NOW, THEREFORE, pursuant to public interest and the provisions of existing laws, rules, and regulations, this Circular is hereby issued, adopted, and promulgated.

Section 1. Scope and Coverage — This Circular serves as the revised and consolidated guidelines for the vulnerability disclosure program. This Circular also establishes the **Safe Harbor Policy and Bug Bounty Program (SHPBBP)** of the DICT.

This Circular shall apply to:

- a. All national government agencies (NGA) under the Executive Branch, including Government-Owned and -Controlled Corporations (GOCCs) and their subsidiaries, Government Financial Institutions (GFIs), and State Universities and Colleges (SUCs), including those under the *.gov.ph domain and DICT-managed platforms;
- b. The Philippine Congress, the Judiciary, Independent Constitutional Commissions, the Office of the Ombudsman, and Local Government Units (LGUs) are highly encouraged to adopt this Circular;
- c. Private entities voluntarily enrolled under the DICT's Public-Private Cybersecurity Partnership Program (PPCP);
- d. Critical Information Infrastructure (CII) operators, as identified under the National Cybersecurity Plan (NCSP); and
- e. Cybersecurity Researchers that are responsible for identifying and analyzing potential threats to an organization's network and systems.

Section 2. Objectives — The Program aims to:

- a. Establish a legal and operational framework for responsible vulnerability disclosure;
- b. Protect ethical hackers acting in good faith under Safe Harbor provisions;
- c. Institutionalize a Bug Bounty mechanism to recognize and reward valid vulnerability reports;
- d. Encourage public-private collaboration in enhancing cybersecurity defenses; and
- e. Promote trust, transparency, and a culture of responsible disclosure across the digital ecosystem.

Section 3. Definition of Terms.

Private Bug Bounty program - restricted to a specific number of handpicked cybersecurity researchers vetted by the PMO and the participating entity. The program rules are not publicly disclosed.

Public Bug Bounty program - an open invitation for cybersecurity researchers to find and report security vulnerabilities in the participating entities' systems in exchange for recognition and monetary rewards.

Section 4. Safe Harbor Policy

4.1. Good Faith Protection — Researchers acting in good faith shall not be subject to administrative, civil, or criminal liability under RA 10175, RA 10173, or other relevant laws, provided that:

- a. They test only declared in-scope systems;
- b. No unauthorized data exfiltration, alteration, or service disruption occurs;
- c. Vulnerabilities are reported responsibly and privately to DICT or the authorized entity; and
- d. No public disclosure occurs prior to resolution or express permission.

4.2. Exclusions from Safe Harbor — Safe Harbor protection shall not apply to actions involving:

- a. Unauthorized data manipulation, exfiltration, deletion, or exposure;
- b. Exploit sales, extortion, or coercion;
- c. Social engineering or phishing;
- d. Denial-of-service attacks;
- e. Unauthorized disclosure of any suspected vulnerability to any third party outside the DICT; or
- f. Tests conducted outside the declared scope.

Section 5. Bug Bounty Program

5.1. The Program — The DICT shall implement a Bug Bounty Program (BBP) as a structured mechanism to incentivize cybersecurity researchers who responsibly disclose verified vulnerabilities in government, CII, and private systems covered under this Circular.

5.2. Reward Framework

Severity	Example Impact	Recognition
Critical	Remote Code Execution, full system compromise	Certificate + Hall of Fame

Severity	Example Impact	Recognition
High	Authentication bypass, privilege escalation	Certificate of Recognition
Medium	IDOR, data exposure, persistent XSS	Hall of Fame Mention
Low	Misconfigurations, information disclosure	Acknowledgment

Rate of the monetary incentives shall be determined and disbursed directly by the participating entities at their own discretion, subject to their internal policies and applicable laws. The participating entity shall be responsible for ensuring that their respective monetary incentive policies and determined rates are posted on the Vulnerability Disclosure Program Portal (VDPP) and updated every six (6) months to reflect the current industry rate.

Private entities may provide additional or higher bounty rewards under their internal cybersecurity programs, subject to DICT review and approval and in compliance to applicable laws.

Section 6. Know Your Contributor (KYC) Guidelines

6.1. Purpose — To ensure accountability, compliance, and transparency in the distribution of rewards, the DICT shall enforce Know Your Contributor (KYC) procedures for all researchers participating in the SHBBP.

6.2. Requirements — All researchers eligible for monetary rewards must complete DICT's KYC verification, which includes submission of requirements to the National Computer Emergency Response Team (NCERT) through the VDPP, to be announced at a later date via a DICT advisory. The requirements are as follows:

- a. Valid government-issued ID (passport, UMID, driver's license, etc.);
- b. Verified contact information (email, phone, and address);
- c. A signed Researcher Participation Agreement (RPA) affirming good-faith intent and consent to DICT's data privacy provisions; and
- d. For researchers participating in the private Bug Bounty Program, a valid NBI Clearance.

6.3. Verification and Non-Compliance

- a. If a researcher fails to complete the KYC process, the report may still be acknowledged as valid but will not qualify for a cash reward.
- b. The researcher will instead receive non-monetary recognition and inclusion in the National Bug Bounty Hall of Fame.

- c. KYC validation must be completed within three (3) business days after confirmation of the report's validity. Failure to comply within this period shall result in forfeiture of any cash reward.

6.4 Conflict of Interest

- a. DICT personnel and third-party service providers engaged by the DICT are not eligible for monetary incentives and recognition under this program for any vulnerability reported on DICT-managed assets and systems.
- b. All other government agencies and participating entities from the private sector shall set their own parameters in identifying conflict of interest in the BBP.

Section 7. Governance and Implementation

7.1. Program Management Office (PMO) — The DICT Cybersecurity Bureau (CSB), which will serve as the Program Management Office (PMO), shall:

- a. Manage vulnerability submission, triage, and coordination;
- b. Operate the VDP Portal;
- c. Verify researcher identity through KYC procedures;
- d. Coordinate with affected entities for mitigation; and
- e. Maintain records of Safe Harbor certificates, bounty payments, and acknowledgments.

7.2. Cybersecurity Researcher - The cybersecurity researcher shall:

- a. Submit KYC requirements to DICT through the VDPP;
- b. Participate in the program for lawful purposes only, and shall comply with all applicable laws, rules, and regulations;
- c. Test only declared in-scope systems, and be solely responsible for the accuracy, completeness, appropriateness, and legality of any data or vulnerabilities they provide through their participation in the program; and
- d. Keep the confidentiality of the reported vulnerability in accordance with this Implementing Guidelines and not disclose to any third-party any data and/or information accessed and/or obtained through or in connection with their participation in the program, unless authorized by the DICT.

7.3. Participating Entities — All participating agencies and organizations shall:

- a. Identify and declare in-scope systems;

- b. Respond to validated reports within one (1) to three (3) business days, depending on the severity;
- c. Ensure privacy, fairness, and confidentiality in all proceedings; and
- d. Collaborate with DICT for bounty validation and issuance.

Section 8. Reporting Procedure — The researcher's submission shall include the full description of the vulnerability with relevant proof-of-concept, name of the agency/organization where the vulnerability was discovered, along with its affected ICT asset/s. Each report shall contain the following information:

- a. Vulnerable Asset/Endpoint;
- b. Vulnerability Name and Description;
- c. Technical details and steps to reproduce;
- d. Proof-of-concept or supporting documentation, including how the suspected vulnerability may impact the subject service; and
- e. Researcher identification (name or pseudonym for acknowledgment).

Vulnerabilities shall be submitted through the VDPP.

The PMO shall acknowledge receipt of the vulnerability report and notify the concerned government agency/agencies of the suspected vulnerability within three (3) business days from the receipt of the report.

The PMO shall coordinate with the vulnerability researcher and concerned government agency/agencies in remediating any validated vulnerability within thirty (30) business days from the acknowledgement of the vulnerability report.

Upon validation of the suspected vulnerability report, the PMO shall provide appropriate certificate/recognition for the researcher's contribution in reporting and/or resolution of the validated vulnerability. The private sector participating entities, with the concurrence of the PMO, may disburse the appropriate monetary reward/incentive based on the structured incentive mechanism established under the VDP.

Section 9. Recognition and Incentives — DICT shall maintain a National Bug Bounty Hall of Fame to honor individuals and organizations demonstrating excellence in vulnerability disclosure. Recognition may include:

- a. Digital and printed certificates;
- b. Public acknowledgment on the VDPP;
- c. Inclusion in other DICT citations.

Section 10. Disclosure — The DICT and the participating entity will jointly issue a public disclosure regarding the reported and remediated vulnerability to promote

transparency and build public trust. Researchers shall not publicly disclose any information about the vulnerability unless authorized in advance by the DICT and relevant stakeholders.

Section 11. Funding — Covered agencies may engage service providers to comply with the requirements of this program, subject to existing procurement laws and regulations.

Private sector partners may provide funding or in-kind support for bounties, training, or promotional activities, subject to existing accounting and auditing regulations.

The funding requirements for the implementation of this Circular shall be charged against the existing budget of the covered agency or institution, and such other appropriate funding sources as the Department of Budget and Management (DBM) may identify, subject to relevant laws, rules, and regulations.

Section 12. Repealing Clause — DICT Department Circular No. 006, s. 2024 titled, “Guidelines for the Vulnerability Disclosure Initiative” is hereby repealed and superseded. All other department circulars or issuances inconsistent with this Circular are hereby amended or repealed accordingly.

Section 13. Effectivity — This Department Circular shall take effect fifteen (15) days upon publication in the DICT website and filing with the Office of the National Administrative Register (ONAR), U.P. Law Center.

Issued this 14 day of JAN, 2026, in Quezon City, Philippines.

Digitally signed
by Aguda
Henry Rhoel
Ratuila
HENRY R. AGUDA
Secretary

Copy furnished:
All concerned.